Universidad Mariano Gálvez de Guatemala.

Centro Universitario de Chiquimula

Facultad de ingeniería

Ingeniería en Sistemas de la Información y Ciencias de la Computación

Análisis de Datos ll

Kelly Esmeralda Posadas Mejia



Laboratorio Pruebas de Seguridad

Ángel Estuardo Ventura Damian 1390-23-14880

Viviana Nohemy García Cardona 1390-23-13570

Oscar David García López 1390-23-11577

Katerin Yamileth Carranza Pérez 1390-23-15421

Chiquimula 19 de octubre

Del 2026

LABORATORIO DE MODELADO Y PRUEBAS DE SEGURIDAD EN SISTEMAS
PARTE GRUPAL

Sistema Reservación de citas para una peluquería

En el presente laboratorio se desarrolló y evaluó un prototipo web llamado CitaFácil, diseñado para administrar las reservaciones de una peluquería. A partir de este sistema se identificaron cinco requerimientos de seguridad, se elaboró un plan de pruebas y se realizaron comprobaciones para observar cómo responde la aplicación ante diferentes situaciones relacionadas con el acceso y la protección de contraseñas.

Asimismo, se utilizaron pruebas automatizadas como apoyo para evaluar otras funciones de seguridad y se investigaron herramientas que permiten identificar vulnerabilidades en aplicaciones web.

1. Descripción del sistema

Nombre: Cita Fácil.

Tipo de sistema: Aplicación web de reservación de citas.

Tecnologías utilizadas: Python, Flask, HTML, CSS y SQLite.

Cita Fácil es un sistema desarrollado con fines académicos que permite a los clientes de una peluquería registrarse, iniciar sesión y reservar citas de acuerdo con los servicios y horarios disponibles.

El sistema cuenta con dos tipos de usuarios:

- Cliente: puede registrarse, iniciar sesión, realizar reservaciones, consultar sus citas y cancelarlas.
- Administrador: puede acceder a un panel administrativo para consultar y administrar las reservaciones.

Información que debe protegerse: nombres de los clientes, correos electrónicos, números telefónicos cuando sean solicitados, contraseñas y datos relacionados con las reservaciones.

Aunque el sistema tiene funciones sencillas, necesita medidas de seguridad para evitar que personas no autorizadas accedan a información privada o realicen modificaciones que no les corresponden.

A. REQUERIMIENTOS DE SEGURIDAD

Los requerimientos de seguridad son condiciones que debe cumplir un sistema para proteger su información y garantizar que los usuarios solamente puedan realizar las acciones autorizadas.

Durante el análisis y diseño de un sistema, estos requerimientos pueden identificarse tomando en cuenta los datos que se almacenarán, los usuarios que tendrán acceso y las posibles amenazas que podrían afectar su funcionamiento.

Para CitaFácil se establecieron los siguientes requerimientos:

Código	Requerimiento	Amenaza o riesgo	Importancia	Forma de comprobarlo
RS-01	El sistema deberá permitir el inicio de sesión únicamente con credenciales válidas.	Accesos no autorizados.	Evita que personas desconocidas ingresen a las cuentas.	Intentar iniciar sesión con una contraseña incorrecta.
RS-02	El sistema deberá restringir las funciones administrativas a usuarios autorizados y evitar que los clientes modifiquen citas ajenas.	Acceso indebido y modificación de información.	Protege las reservaciones y las funciones administrativas.	Intentar ingresar a /admin con una cuenta de cliente y comprobar el acceso a citas ajenas.
RS-03	El sistema deberá utilizar consultas parametrizadas para las operaciones con la base de datos.	Inyección SQL.	Ayuda a evitar que datos manipulados alteren las consultas y afecten la información almacenada.	Revisar las consultas del código y verificar el uso de parámetros.
RS-04	El sistema deberá validar los datos introducidos y evitar que el contenido proporcionado por los usuarios se ejecute como código.	XSS y entradas maliciosas.	Ayuda a mantener la integridad y seguridad de los formularios.	Ingresar datos de prueba y comprobar que se muestran de forma segura.
RS-05	El sistema deberá exigir contraseñas de al menos 10 caracteres, aplicar controles para evitar contraseñas comunes y limitar los intentos fallidos de inicio de sesión.	Contraseñas débiles y ataques de fuerza bruta.	Dificulta el acceso no autorizado a las cuentas.	Probar contraseñas cortas y comunes, además de verificar los límites de intentos fallidos.

B. PLANIFICACIÓN DE PRUEBAS DE SEGURIDAD

Objetivo

Evaluar el comportamiento de CitaFácil mediante pruebas que permitan comprobar algunas de las medidas implementadas para proteger las cuentas, las reservaciones y la información de los usuarios.

Alcance

Las pruebas se enfocan en las siguientes partes del sistema:

- Formulario de inicio de sesión.
- Formulario de registro de usuarios.
- Panel administrativo.
- Acceso a las reservaciones.
- Validación de datos.
- Operaciones relacionadas con la base de datos.

Tipos de pruebas

Se consideran principalmente pruebas de caja negra, que permiten evaluar el comportamiento de la aplicación utilizando sus funciones sin necesidad de revisar el código fuente.

También se contempla la prueba de caja blanca para revisar la implementación de las consultas a la base de datos. Como complemento, se utilizaron pruebas automatizadas con pytest para verificar determinados comportamientos.

Plan de pruebas

Prueba	Requerimiento	Tipo	Prioridad	Criterio de aprobación
Acceso al sistema	RS-01	Caja negra	Alta	El sistema rechaza el inicio de sesión con credenciales incorrectas.
Control de acceso según el rol	RS-02	Caja negra	Alta	Un cliente no puede ingresar al panel administrativo ni realizar operaciones sobre citas ajenas.
Protección de consultas SQL	RS-03	Caja blanca	Alta	Las consultas utilizan parámetros y los datos introducidos no alteran su estructura.
Validación de formularios	RS-04	Caja negra	Media	Los datos inválidos son rechazados cuando corresponde y el contenido introducido por usuarios no se ejecuta como código.
Seguridad de contraseñas	RS-05	Caja negra	Alta	Se exige una longitud mínima de 10 caracteres, se rechazan contraseñas comunes y se limitan los intentos fallidos de acceso.

Prioridad de las pruebas

Las pruebas de acceso, control de permisos y contraseñas tienen prioridad alta porque una falla podría permitir el ingreso de personas no autorizadas. La protección de consultas SQL también se considera prioritaria debido al riesgo que representa para la información almacenada.

La validación de formularios tiene prioridad media dentro de este plan, aunque también es necesaria para evitar entradas maliciosas y problemas en el funcionamiento de la aplicación.

Criterios de aprobación

Una prueba se considera aprobada cuando el comportamiento observado coincide con el resultado esperado.

Si el sistema permite una acción prohibida o incumple el requerimiento establecido, la prueba se considera fallida o parcialmente satisfactoria, según las comprobaciones realizadas.

Los controles que no se han evaluado deberán identificarse como pendientes, sin asumir que funcionan correctamente.

C. EJECUCIÓN DE PRUEBAS DE SEGURIDAD

Para esta actividad se realizaron dos pruebas manuales de caja negra en el prototipo CitaFácil, utilizando un navegador web y cuentas creadas para el laboratorio.

Prueba 1. Control de acceso al panel administrativo

Requerimiento: RS-02, control de acceso según el rol.

Objetivo: Comprobar que un usuario registrado como cliente no pueda ingresar a las funciones exclusivas del administrador.

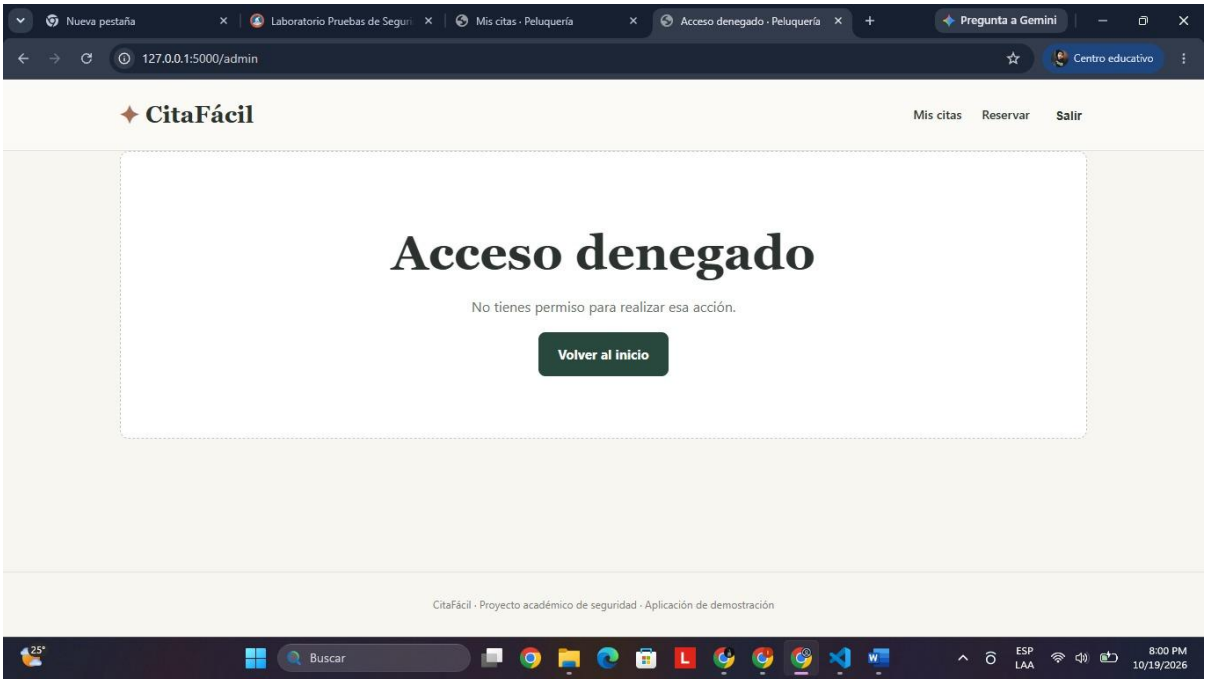
Procedimiento: Se inició sesión en CitaFácil utilizando una cuenta de cliente. Posteriormente, se abrió una nueva pestaña del navegador y se ingresó directamente a la dirección http://127.0.0.1:5000/admin, con la intención de acceder al panel administrativo.

Resultado esperado: El sistema debía impedir el ingreso del cliente al panel y mostrar un mensaje de acceso denegado o rechazar la solicitud.

Resultado obtenido: Al intentar acceder, la aplicación mostró el mensaje «Acceso denegado», por lo que el cliente no pudo visualizar el panel administrativo.

Estado de la prueba: Aprobada para el escenario evaluado.

Recomendación si falla: Revisar los permisos de los usuarios y comprobar que las restricciones se apliquen desde el servidor, evitando que un cliente pueda acceder a funciones exclusivas del administrador mediante direcciones directas.



Resultado de la prueba de control de acceso al panel administrativo.

Prueba 2. Validación de longitud mínima de contraseñas

Requerimiento: RS-05, seguridad de contraseñas.

Objetivo: Comprobar si el formulario de registro exige una contraseña de al menos 10 caracteres.

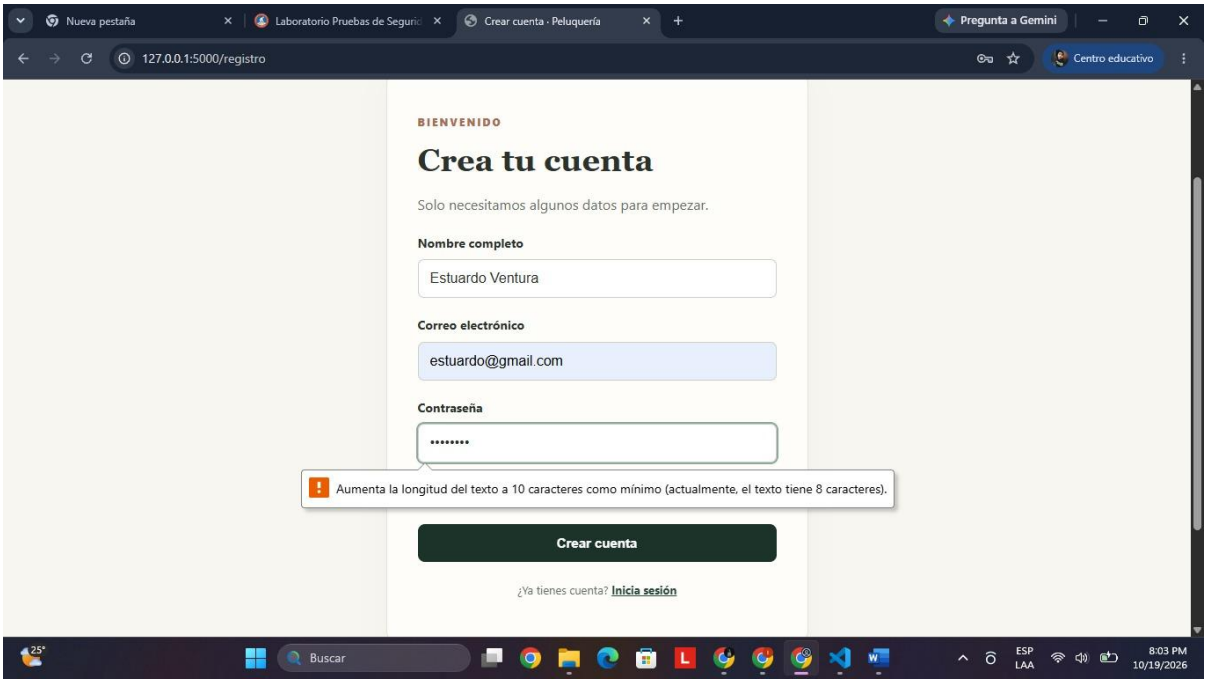
Procedimiento: Se ingresó al formulario de registro y se completaron los datos necesarios para crear una cuenta. En el campo de contraseña se escribió 12345678, que contiene ocho caracteres. Posteriormente, se intentó registrar la cuenta para observar la respuesta del sistema.

Resultado esperado: El formulario debía impedir continuar con el registro y solicitar una contraseña de al menos 10 caracteres.

Resultado obtenido: El navegador mostró un mensaje solicitando aumentar la longitud de la contraseña a un mínimo de 10 caracteres. Debido a esta restricción, no permitió enviar el formulario con la contraseña introducida.

Estado de la prueba: Aprobada en la validación de longitud mínima realizada desde el navegador. No se comprobó mediante esta prueba manual que el servidor aplique la misma restricción.

Recomendación: Mantener el requisito de longitud mínima y aplicar la validación también desde el servidor para evitar que pueda omitirse. Además, se recomienda comprobar las contraseñas comunes o comprometidas.



Validación de contraseña de al menos 10 caracteres.

Hallazgo adicional sobre contraseñas

Durante las comprobaciones también se intentó registrar una cuenta utilizando la contraseña 1234567890.

Aunque esta contraseña cumple con la longitud mínima de 10 caracteres, es una secuencia numérica común y fácil de adivinar. La aplicación permitió crear la cuenta y el navegador Chrome mostró una advertencia relacionada con la exposición de esa contraseña en filtraciones de datos.

Este resultado permitió identificar que la longitud mínima, por sí sola, no garantiza que una contraseña sea segura.

Por lo tanto, aunque la validación de longitud del formulario funcionó, el requerimiento RS-05 necesita mejoras para rechazar más contraseñas comunes. La comprobación manual no incluyó el límite de intentos fallidos.

Pruebas automatizadas complementarias

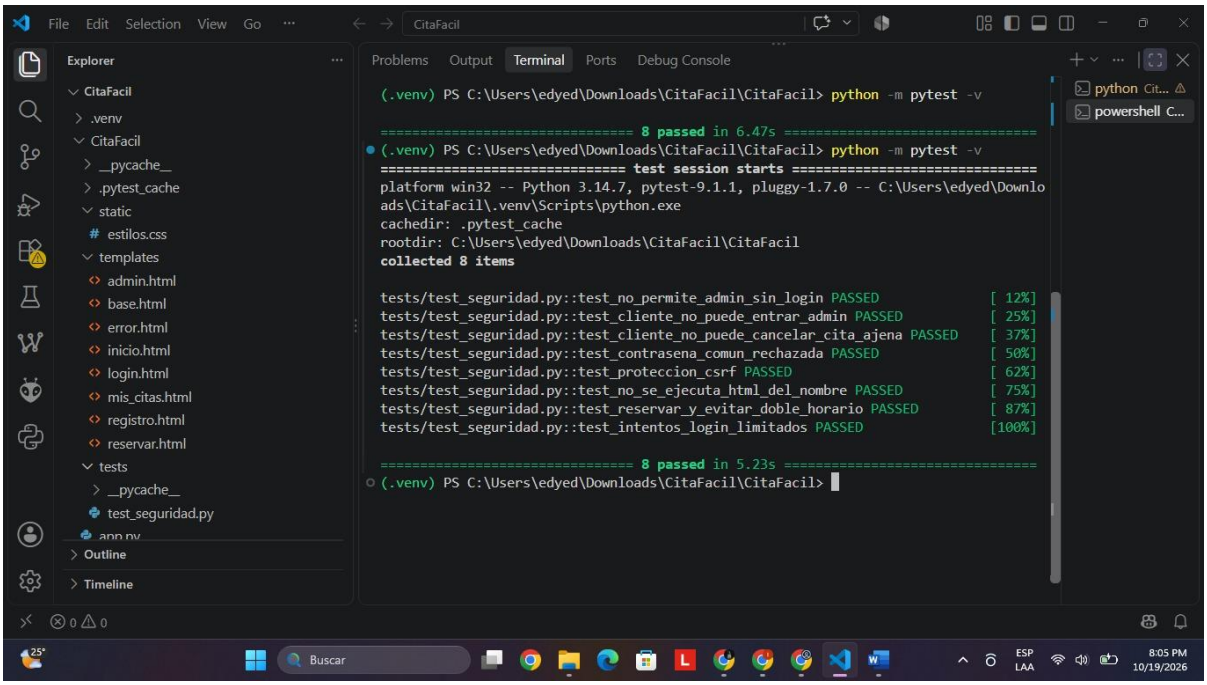
Además de las comprobaciones manuales, se ejecutaron ocho pruebas automatizadas utilizando pytest.

Prueba automatizada	Resultado
Restricción de acceso al administrador sin iniciar sesión	Aprobada
Restricción de acceso al administrador desde una cuenta de cliente	Aprobada
Protección frente a la cancelación de citas ajenas	Aprobada
Rechazo de una contraseña común en el caso automatizado	Aprobada
Protección frente a solicitudes CSRF	Aprobada
Manejo seguro del contenido HTML introducido en nombres	Aprobada
Reservación y prevención de horarios duplicados	Aprobada
Limitación de intentos incorrectos de inicio de sesión	Aprobada

Resultado general: 8 pruebas aprobadas de 8 ejecutadas, en 5.23 segundos.

Estos resultados permiten comprobar los casos específicos definidos en las pruebas automatizadas. Sin embargo, no significan que la aplicación esté libre de vulnerabilidades.

En particular, la aceptación manual de 1234567890 demuestra que es necesario ampliar los casos de prueba de contraseñas.



Ejecución de ocho pruebas automatizadas mediante pytest en 5.23 segundos.

D. COMPARACIÓN DE HERRAMIENTAS PARA PRUEBAS DE SEGURIDAD

Para conocer otras alternativas que permiten evaluar la seguridad de aplicaciones web, se investigaron OWASP ZAP y Burp Suite.

Aspecto	OWASP ZAP	Burp Suite
Función	Herramienta para analizar la seguridad de aplicaciones web.	Plataforma para inspeccionar y evaluar la seguridad de aplicaciones web.
Tipo de pruebas	Análisis pasivo, escaneo activo y pruebas automatizadas.	Interceptación de solicitudes, análisis manual y escaneo según la edición.
Ventajas	Gratuita, de código abierto y con documentación disponible.	Permite examinar detalladamente las solicitudes y respuestas del sistema.
Limitaciones	Sus alertas necesitan verificarse y puede no detectar fallas de lógica.	Algunas funciones avanzadas requieren una versión de pago.
Uso responsable	Se utiliza en sistemas propios o con autorización.	Se utiliza únicamente en sistemas propios o autorizados.

Herramienta seleccionada

Como equipo elegiríamos OWASP ZAP porque es una herramienta gratuita que ofrece funciones útiles para analizar la seguridad de aplicaciones web.

Consideramos que sería adecuada para CitaFácil porque permitiría examinar el tráfico web e identificar posibles problemas en solicitudes, respuestas y configuraciones de seguridad.

Sin embargo, sus resultados tendrían que verificarse antes de aplicar correcciones, ya que una alerta no siempre representa una vulnerabilidad confirmada.

Nota: la herramienta fue investigada como parte del laboratorio, pero no se utilizó para realizar las pruebas documentadas. Las pruebas automatizadas se ejecutaron con pytest.

CONCLUSIÓN GRUPAL

El desarrollo de este laboratorio nos permitió comprender que la seguridad debe tomarse en cuenta incluso en aplicaciones sencillas. Aunque CitaFácil solamente administra reservaciones, contiene información de los usuarios que necesita protección frente a accesos indebidos y posibles modificaciones.

Durante las pruebas comprobamos que el sistema restringe el ingreso de un cliente al panel administrativo y que el formulario exige una longitud mínima para las contraseñas. Sin embargo, también identificamos que es posible registrar una contraseña común, lo cual demuestra que cumplir una condición de longitud no siempre significa contar con una contraseña segura.

Como equipo consideramos que el control de acceso debe ser una prioridad, porque ayuda a evitar que los usuarios realicen acciones que no les corresponden. También reconocimos la importancia de fortalecer la validación de contraseñas, ya que representa otra medida fundamental para proteger las cuentas.

Finalmente, aprendimos que una prueba aprobada no significa que todo el sistema sea seguro. Es necesario revisar diferentes escenarios, comparar los resultados y realizar mejoras cuando se identifican debilidades.

7. Referencias bibliográficas

Appium. (s. f.). Appium documentation. https://appium.io/docs/en/latest/

OWASP Foundation. (s. f.). Web Security Testing Guide. https://owasp.org/www-project-web-security-testing-guide/

OWASP Foundation. (s. f.). Authentication Cheat Sheet. https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html

OWASP ZAP. (s. f.). ZAP documentation. https://www.zaproxy.org/docs/

PortSwigger. (s. f.). Burp Suite documentation. https://portswigger.net/burp/documentation

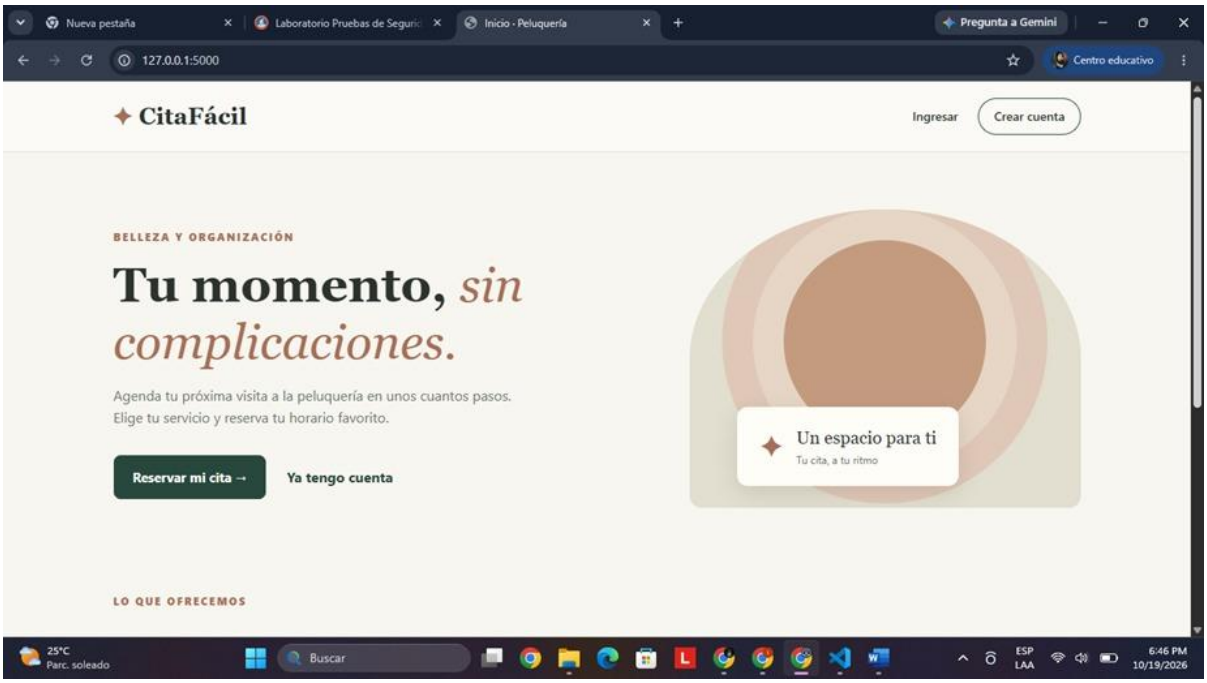
8. Declaración del uso de inteligencia artificial

Para la realización del laboratorio se utilizó ChatGPT como apoyo en la organización del informe, la explicación de conceptos de seguridad y la elaboración inicial del prototipo CitaFácil. La información técnica se contrastó con documentación oficial de OWASP y las herramientas investigadas.

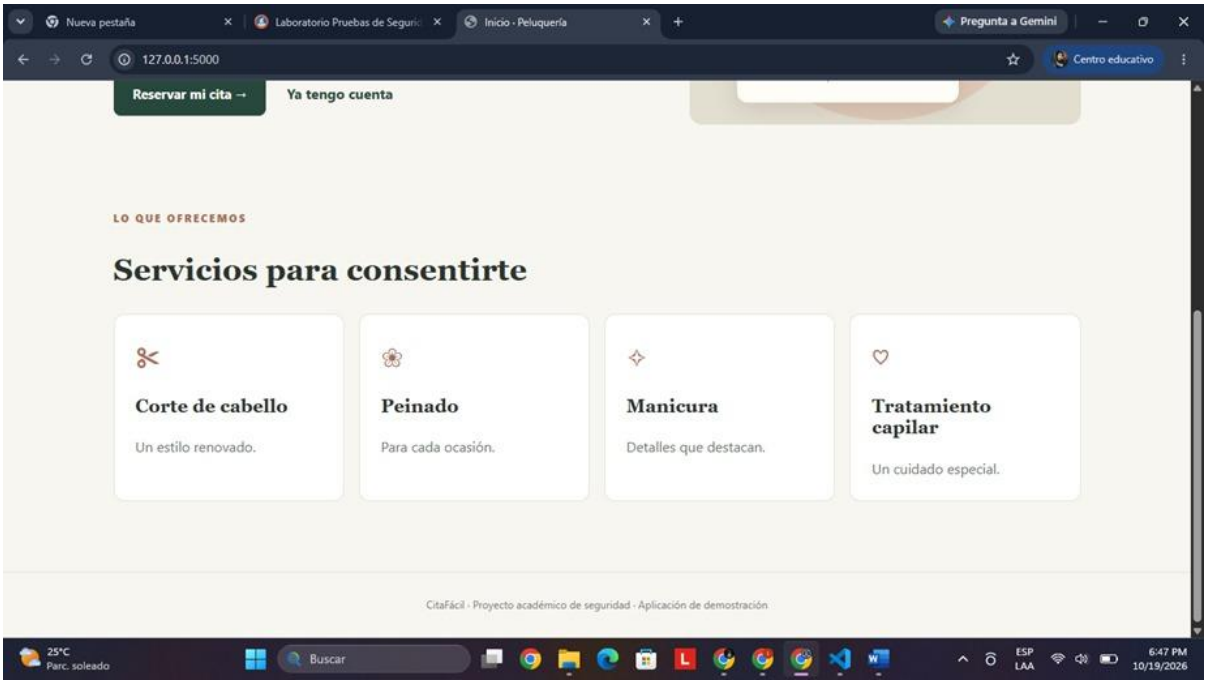
Las pruebas manuales se realizaron en el entorno local de la aplicación y las pruebas automatizadas se ejecutaron mediante pytest. Los resultados presentados corresponden a las comprobaciones realizadas y no a resultados generados por inteligencia artificial.

ANEXOS Evidencias del funcionamiento general de CitaFácil

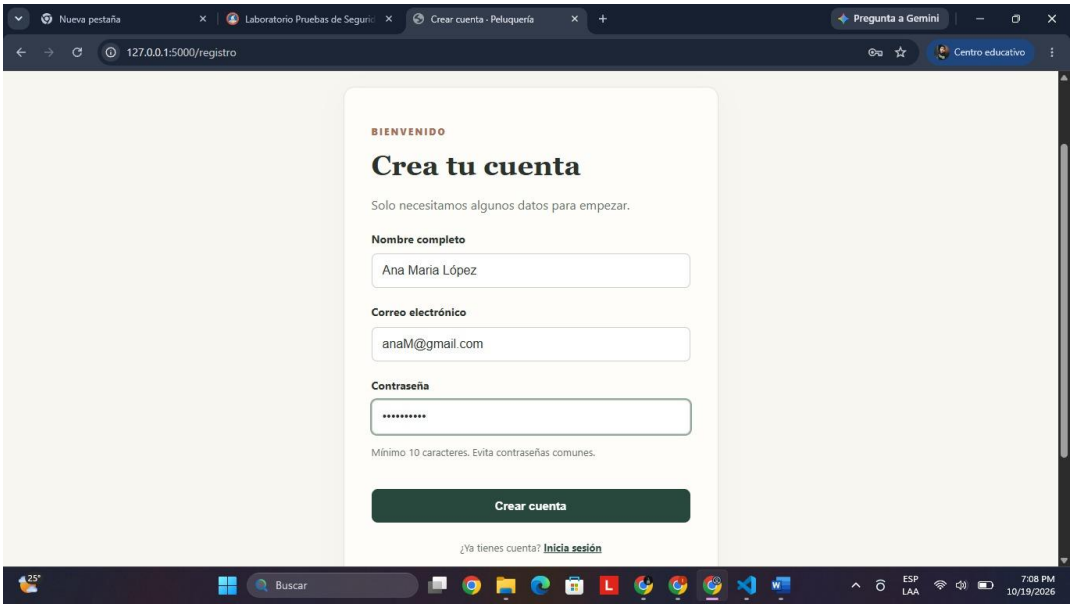
Las siguientes capturas documentan el flujo general utilizado durante la preparación del entorno de prueba: ingreso al sistema, creación de una cuenta, inicio de sesión y reservación de una cita. Estas evidencias brindan contexto sobre el prototipo, pero no sustituyen las pruebas de seguridad presentadas en el inciso C.



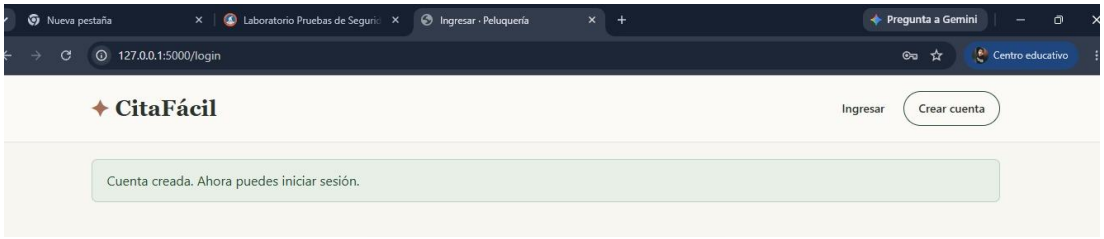
Vista de inicio de CitaFácil.



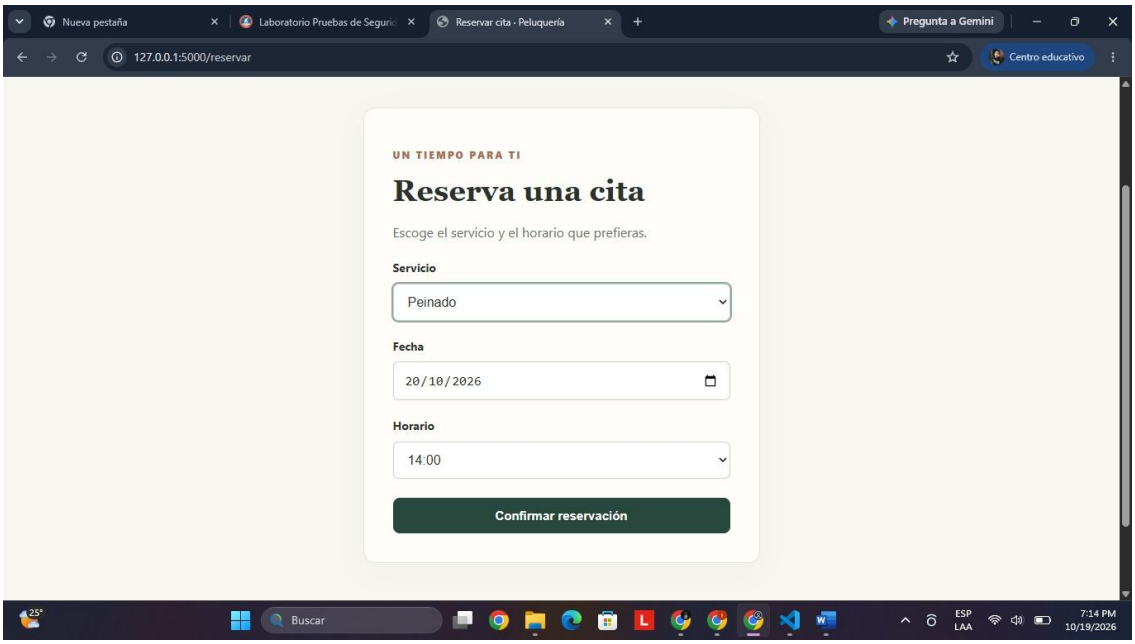
Servicios disponibles en CitaFácil.



Formulario de creación de una cuenta de cliente.



Confirmación de la creación de la cuenta.



Formulario para reservar una cita.